

COMSM0120_2024_TB-2

Security of Industrial Control System

Group Assessment for MSc ICS security

Group 10

2451975 Yatish Waghmare

2550167 Heyang Liu

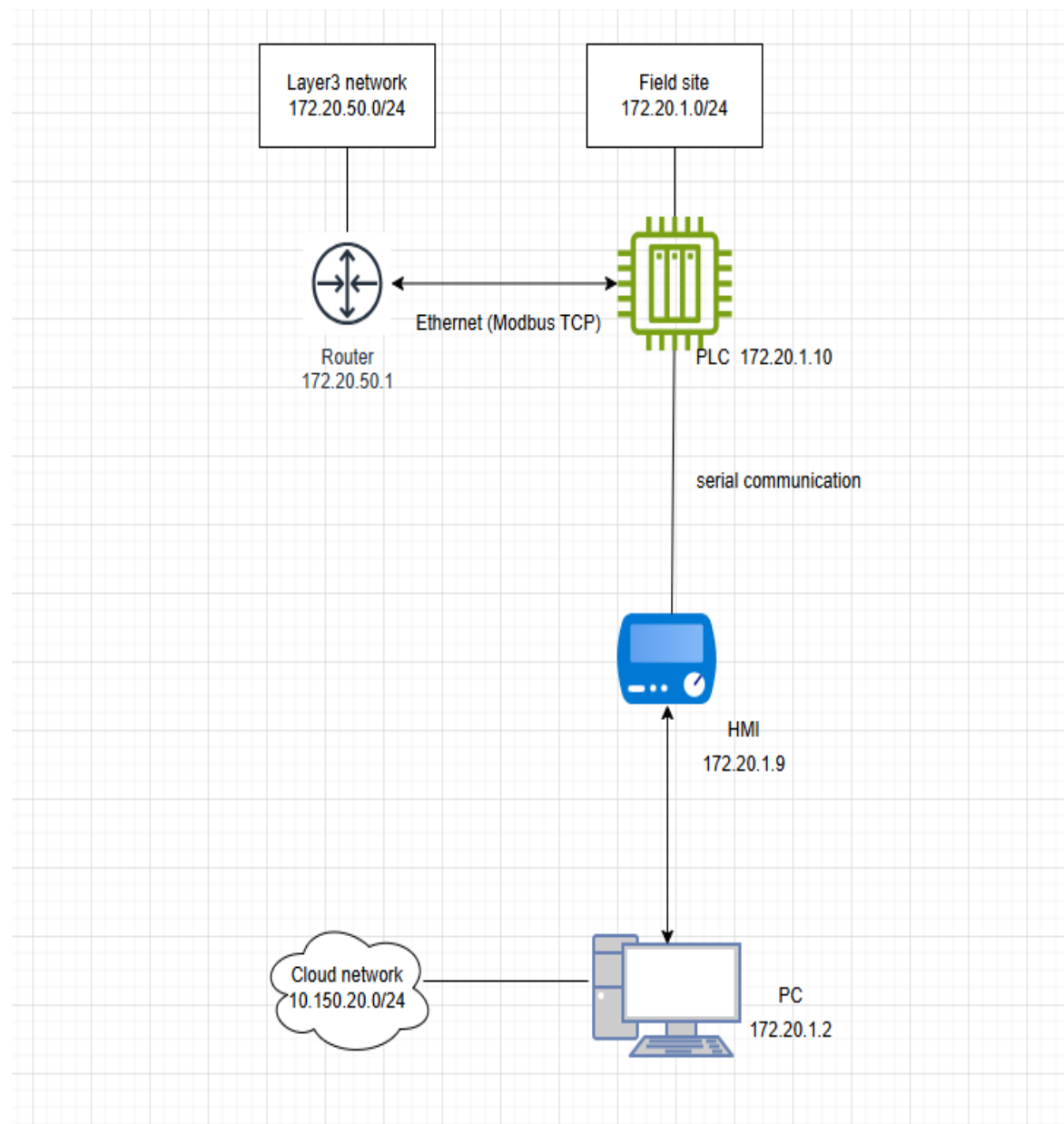
2515634 Sapphire Liu

Word Count:

Faculty of Engineering

School of Computer Science

University of Bristol



INTRODUCTION

Industrial Control Systems (ICSs) are crucial in today's industry because they automate processes, control distributed systems, and monitor operations. Initially, ICSs were meant to work in isolated environments or connect to other systems using specialized communication methods. This design gave manufacturers the ability to manage their production processes safely and flexibly.

However, this setup doesn't meet the current need to use advanced technologies like the Internet of Things (IoT) and big data analytics. To meet these demands, many ICSs are now linked to enterprise networks, allowing business users to access real-time data from power plants. While this new design improves efficiency, it also introduces various cybersecurity challenges for ICSs.

Objective

This penetration testing report documents the findings from a detailed security analysis of the testbed. The key objectives include:

Asset Discovery: Identifying all active hosts and their roles within the ICS network.

Exploitation and Evidence Collection: Demonstrating proof-of-concept (PoC) exploits for discovered vulnerabilities, providing clear documentation and supporting screenshots.

Mitigation Strategies: Recommending defensive measures to improve the resilience of the system.

Indicators of Compromise (IoCs): Identifying forensic artifacts that could help detect exploitation attempts.

1. Asset Discovery

Firstly, we have to connect ICS Kali to openVPN, as we were given the vpn files we have to copy the configs of client to /etc/openvpn, then type 'sudo openvpn --config /etc/openvpn/client.ovpn' into a terminal, then kali has connected to the private Bristol cyber security testbed where we can start our pentration as seen in Figure 1.

```
kali@kali:~/Desktop$ sudo openvpn --config /etc/openvpn/client.ovpn
[sudo] password for kali:
2025-03-13 06:02:25 WARNING: Compression for receiving enabled. Compression has been used in the past to break encryption. Sent packets are not
compressed unless "allow-compression yes" is also set.
2025-03-13 06:02:25 DEPRECATED OPTION: --cipher set to 'AES-256-CBC' but missing in --data-ciphers (AES-256-GCM:AES-128-GCM). Future OpenVPN v
ersion will ignore --cipher for cipher negotiations. Add 'AES-256-CBC' to --data-ciphers or change --cipher 'AES-256-CBC' to --data-ciphers-fa
ilback 'AES-256-CBC' to silence this warning.
2025-03-13 06:02:25 WARNING: file '/etc/openvpn/client/client1.key' is group or others accessible
2025-03-13 06:02:25 OpenVPN 2.5.7 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO] [LZ4] [EPOLL] [PKCS11] [MH/PTINFO] [AEAD] built on Jul  5 2022
2025-03-13 06:02:25 library versions: OpenSSL 3.3.2 3 Sep 2024, LZO 2.10
2025-03-13 06:02:25 Outgoing Control Channel Authentication: Using 256 bit message hash 'SHA256' for HMAC authentication
2025-03-13 06:02:25 Incoming Control Channel Authentication: Using 256 bit message hash 'SHA256' for HMAC authentication
2025-03-13 06:02:25 TCP/UDP: Preserving recently used remote address: [AF_INET]192.168.5.19:1194
2025-03-13 06:02:25 Socket Buffers: R=[212992->212992] S=[212992->212992]
2025-03-13 06:02:25 UDP link local: (not bound)
2025-03-13 06:02:25 UDP link remote: [AF_INET]192.168.5.19:1194
2025-03-13 06:02:25 TLS: Initial packet from [AF_INET]192.168.5.19:1194, sid=19f80517 770f2d9c
2025-03-13 06:02:25 VERIFY OK: depth=1, CN=Easy-RSA CA
2025-03-13 06:02:25 VERIFY KU OK
2025-03-13 06:02:25 Validating certificate extended key usage
2025-03-13 06:02:25 ++ Certificate has EKU (str) TLS Web Server Authentication, expects TLS Web Server Authentication
2025-03-13 06:02:25 VERIFY EKU OK
2025-03-13 06:02:25 VERIFY OK: depth=0, CN=server
2025-03-13 06:02:25 Control Channel: TLSv1.3, cipher TLSv1.3 TLS AES 256 GCM SHA384, peer certificate: 2048 bit RSA, signature: RSA-SHA256
2025-03-13 06:02:25 [server] Peer Connection Initiated with [AF_INET]192.168.5.19:1194
2025-03-13 06:02:25 PUSH: Received control message: 'PUSH_REPLY,route 172.20.1.0 255.255.255.0,route 172.20.50.0 255.255.255.0,route 10.150.20
.0 255.255.255.0,dhcp-option DNS 8.8.8.8,dhcp-option DNS 8.8.4.4,redirect-gateway def1,dhcp-option DNS 8.8.8.8,dhcp-option DNS 1.1.1.1,route-g
ateway 10.8.0.1,topology subnet,ping 10,ping-restart 120,ifconfig 10.8.0.2 255.255.255.0,peer-id 0,cipher AES-256-GCM'
2025-03-13 06:02:25 OPTIONS IMPORT: timers and/or timeouts modified
2025-03-13 06:02:25 OPTIONS IMPORT: --ifconfig/up options modified
2025-03-13 06:02:25 OPTIONS IMPORT: route options modified
2025-03-13 06:02:25 OPTIONS IMPORT: route-related options modified
2025-03-13 06:02:25 OPTIONS IMPORT: --ip-win32 and/or --dhcp-option options modified
```

Figure 1

After connecting to the VPN successfully, I did the scanning for the given network segment with nmap command to figure out the hosts connected to the system is the first thing to do. Command nmap -sn and -sV both works. Since -sV only scans 1000 the most frequently used ports and -p scans all the 65535 ports, the result may have a little difference between scanning the segment and scanning the hosts separately.

Scan the network segment 172.20.1.0/24 with command nmap -sV.

```

kali@kali:~/Desktop$ nmap -sV 172.20.1.0/24
Starting Nmap 7.93 ( https://nmap.org ) at 2025-03-13 06:07 EDT
Nmap scan report for 172.20.1.1
Host is up (0.0037s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
53/tcp    open  domain Unbound
80/tcp    open  http   nginx

Nmap scan report for 172.20.1.9
Host is up (0.026s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
5001/tcp   open  complex-link?
5002/tcp   open  rfe?

Nmap scan report for 172.20.1.10
Host is up (0.0051s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
80/tcp    open  http
443/tcp   open  ssl/https
2 services unrecognized despite returning data. If you know the service/version, please submit the following fingerprints at https://nmap.org/cgi-bin/submit.cgi?new-service :
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
SF:Port80-TCP:V=7.93%I=7%0=3/13%Time=67D2AE80%P=x86_64-pc-linux-gnu%r(GetR
SF:request,BB,"HTTP/1.0\x20302\x20object\x20Moved\r\nContent-Type:\x20text
SF:/html;\x20charset=UTF-8\r\nCache-Control:\x20no-cache\r\nPragma:\x20no-
SF:cache\r\nExpires:\x200\r\nLocation:\x20/Default.mws\r\nContent-Length
SF::\x200\r\nConnection:\x20close\r\n\r\n")%r(HTTPOptions,BB,"HTTP/1.0\x2
SF:0302\x20object\x20Moved\r\nContent-Type:\x20text/html;\x20charset=UTF-8
SF:\r\nCache-Control:\x20no-cache\r\nPragma:\x20no-cache\r\nExpires:\x200\
SF:r\nLocation:\x20/Default.mws\r\nContent-Length:\x200\r\nConnection:\x
SF:20close\r\n\r\n")%r(FourOhFourRequest,6E,"HTTP/1.0\x20404\x20NOT\x20FO
SF:UND\r\nContent-Type:text/html\r\nContent-Length:22\r\nConnection:\x20cl
SF:ose\r\n\r\n<3>404\x20NOT\x20FOUND</3>");

```

Figure 2

```

Nmap scan report for 172.20.1.70
Host is up (0.0074s latency).
Not shown: 990 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
135/tcp    open  msrpc      Microsoft Windows RPC
139/tcp    open  netbios-ssn Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup: ICS-LAB-0T)
1025/tcp   open  msrpc      Microsoft Windows RPC
1026/tcp   open  msrpc      Microsoft Windows RPC
1027/tcp   open  msrpc      Microsoft Windows RPC
1043/tcp   open  msrpc      Microsoft Windows RPC
1048/tcp   open  msrpc      Microsoft Windows RPC
1947/tcp   open  http       Aladdin/SafeNet HASP license manager 20.03
3389/tcp   open  ssl/ms-wbt-server?
Service Info: Host: KEPMWARE-SERVER; OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for 172.20.1.100
Host is up (0.012s latency).
Not shown: 994 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
135/tcp    open  msrpc      Microsoft Windows RPC
139/tcp    open  netbios-ssn Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
3389/tcp   open  ms-wbt-server Microsoft Terminal Services
4002/tcp   open  mlchat-proxy?
27000/tcp  open  flexlm      FlexLM license manager
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for 172.20.1.150
Host is up (0.0027s latency).
Not shown: 999 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh       OpenSSH 9.7p1 Ubuntu 7ubuntu4 (Ubuntu Linux; protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (8 hosts up) scanned in 153.11 seconds
kali@kali:~/Desktop$

```

Figure 3

2. Exploitation and Evidence Collection

In Figure 3, I have found out that ms-wbt-server which is RDP (Remote Desktop protocol). For which I used to do Rdp but found out it has a windows system which has Kali user and have a password. I tried default password for username kali but was unsuccessful.

But as we did nmap scan we found out that there was an IP where It had webpage, I tried to do <http://172.20.1.30> and got a webpage of a CCTV camera. As I have also done IOT labs I was able to login the webpage as it didn't have any username or password. Below, In Figure 4 is the nmap scan.

```
Nmap scan report for 172.20.1.19  
Host is up (0.014s latency).  
Not shown: 999 closed tcp ports (conn-refused)  
PORT      STATE SERVICE VERSION  
5900/tcp open  vnc     VNC (protocol 3.8)
```



```
Nmap scan report for 172.20.1.30  
Host is up (0.0030s latency).  
Not shown: 999 closed tcp ports (conn-refused)  
PORT      STATE SERVICE VERSION  
9081/tcp open  cisco-aqos?  
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :  
SF-Port9081-TCP-V=7.93%I=7d0/3=13%Time=67D2AE86P=x86_64-pc-linux-gnu/r(Ge  
SF-xel1\0x80Ex1f\0MM\0*\0\0\0x80\0x03\0x012\0x02\0\0\0x14\0\0P\0x87  
SF:1\0\0x4\0\0\0\01\0\0\002\088*\0\0x08\0\0\0\01\0\0\0\0\0\0\0\0\0x2\0  
SF:x90\0\0x07\0\0\0\0x040220\x90\03\0\0x02\0\0\0\0x14\0\0\0d\0\0\0x002025:  
SF:03:13\x2010:07:56\x002025:03:13\x2010:07:56\0\xff\xdb\0C\0\0x05\x03\x04\  
SF:x04\0x04\x03\x05\x04\x04\x04\x05\x05\x05\x06\x07\x0c\x08\x07\x07\x07  
SF:\x0f\x0b\x0b\t\x0c\x11\x0f\x12\x12\x11\x0f\x11\x11\x13\x16\x1c\x17\x13\  
SF:\x14\x1a\x15\x11\x11\x18!\x18\x1a\x1d\x1d\x1f\x1f\x1f\x13\x17!"$%\x1e  
SF:$%1c\x1e\x1f\x1e\xff\xdb\0C\0\0x05\x05\x05\x07\x06\x07\x0e\x08\x08\x0  
SF:e\x1e\x14\x11\x14\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e  
SF:1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e  
SF:1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e\x1e  
SF:1e\xff\xc0\0x11\x08\x02\0x05\0x03\0x01"\0\0x02\x11\x01\x03\x11\x0  
SF:1\xffxc4\0\x1f\0\0x01\x05\x01\x01\x01\x01\x01\x01\0\0\0\0\0\0\0x01  
SF:\x02\x03\x04\x05\x06\x07\x08\t\n\r\x0b\xffxc4\0x05\x10\0\x02\x01\x03\x0  
SF:3:3z7zv8\0v93:v95\0v4\0v4\0v1\0v1\0v2\0v3\0v4\0v11\0v5\x12\0
```

Figure 4

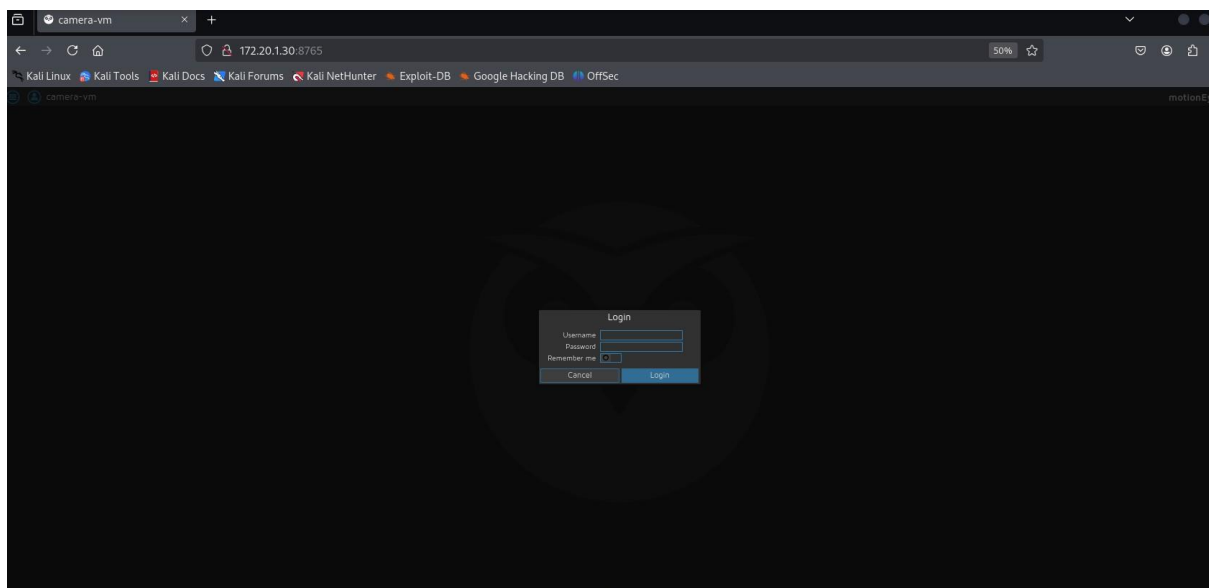


Figure 5

In the above Figure 5, we can see that there opens a CCTV camera feed where after login, we can see the username and password clearly in figure 6.

This helps as I had the RDP connection before so now I can use this username and password to login.

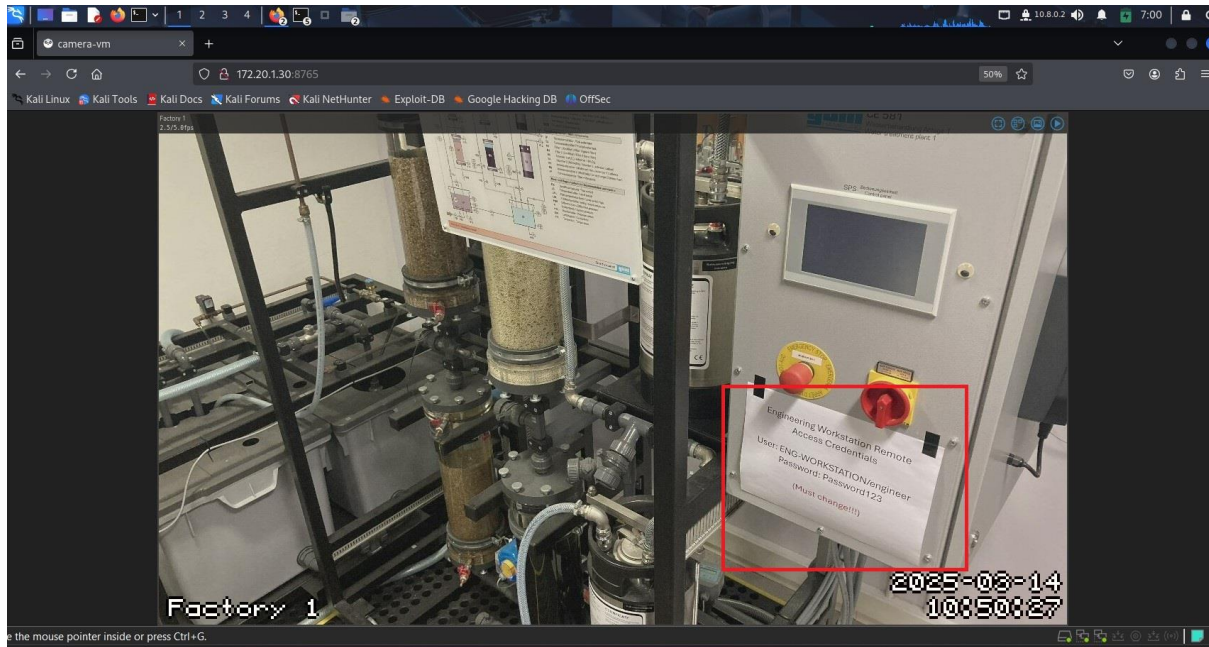


Figure 6

As I did RDP connection to the 172.20.1.100 there opens a new window where I can see a windows login where I can put engineer as username and Password123 as password as seen in Figure 7.

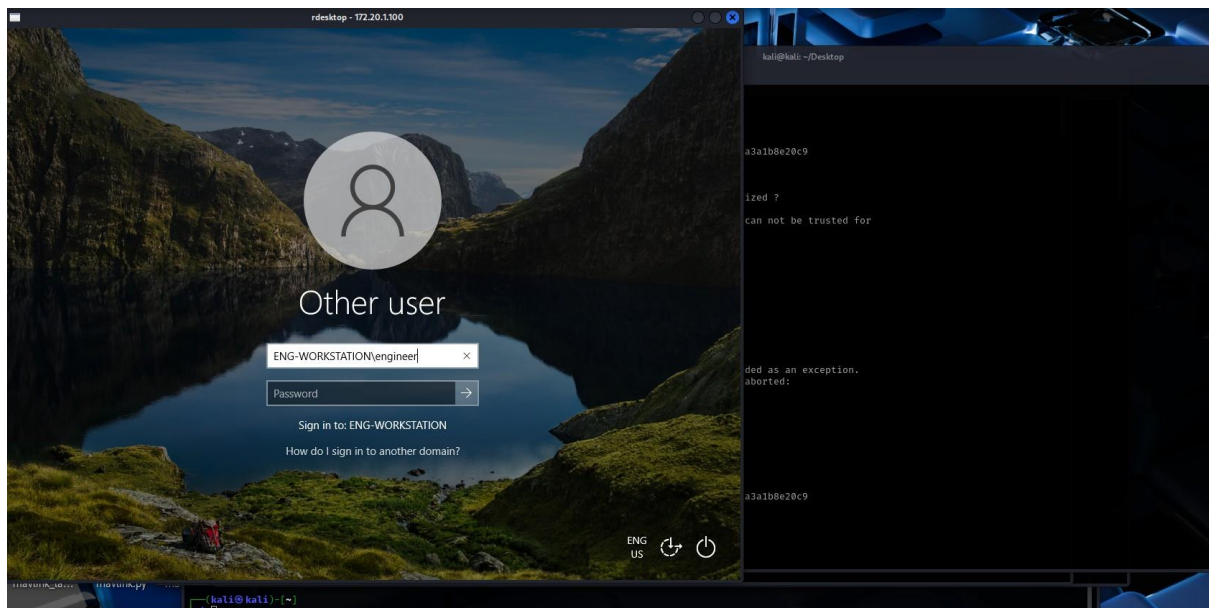


Figure 7

After login I can see the Engineers PC where there was Tia portal, Tia Administrator, Connected component workbench etc. The Engineer also had a sticky note where the domain's username and password was written as seen in Figure 8.

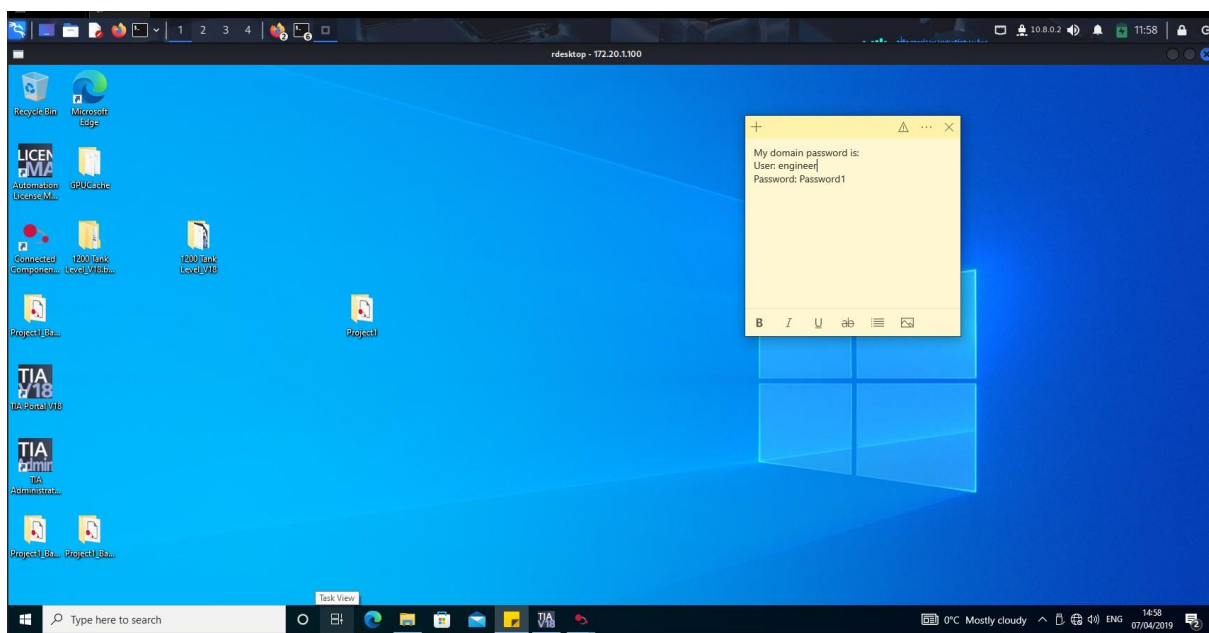


Figure 8

I quickly opened Tia portal as I can open the Tank project which was also there in the engineer's desktop. There I can see PLC as well as HMI I just needed to fo

online for this I asked my supervisor which ss my box. As I needed to be sure that this is my box, I flashed LED, and it got flashed.

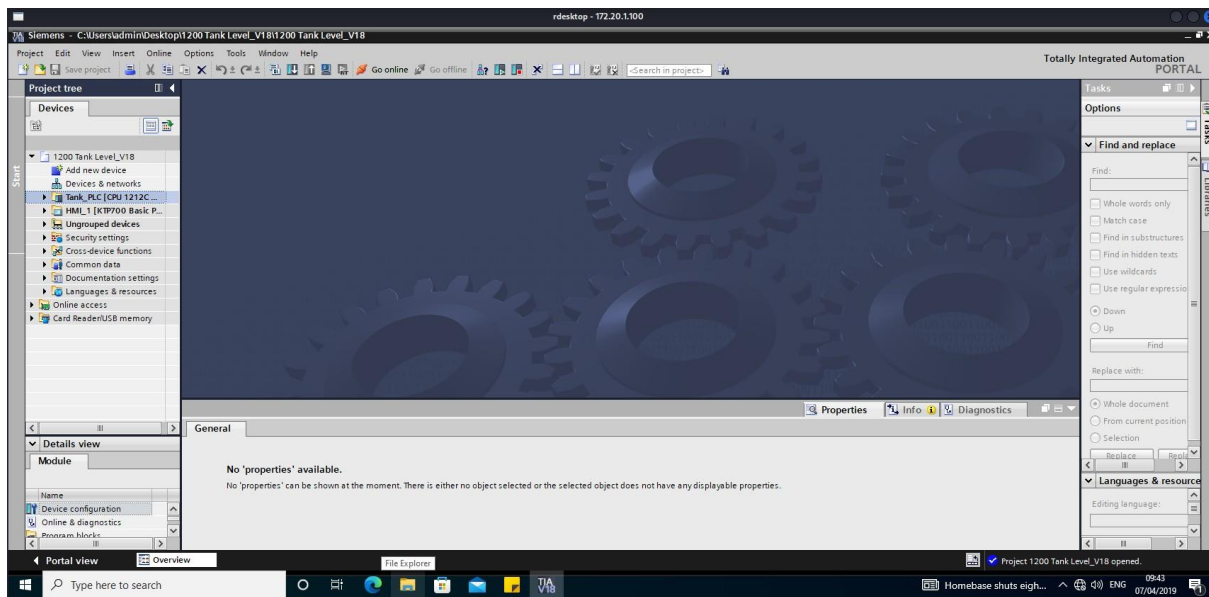


Figure 9

I quickly went online to see if it works, and it did work. After that I remembered the class where we were taught Program block and logic codes. I tried to change the logic for filling control, discharge and Alarm. I just changed the number where the threshold value for discharge was when the level was 8 discharge the water, I changed it to 30. So that the whole water plant would be a swimming pool. In the figure 10 we can see that I have changed the logic.

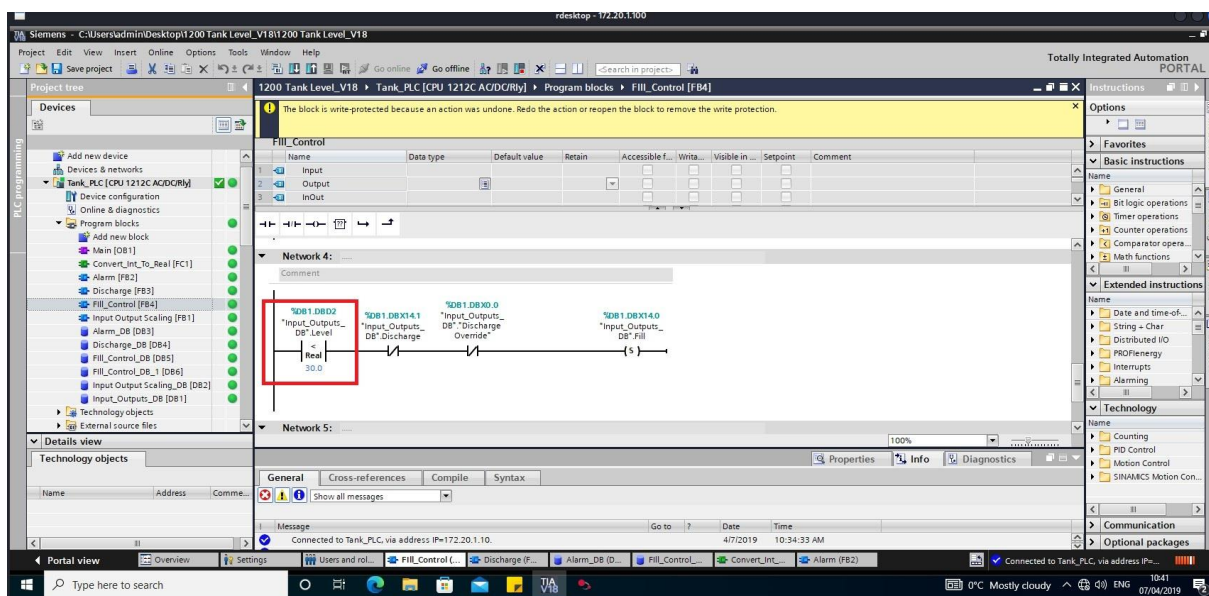


Figure 10

I also changed the alarm logic code and discharge logic code to 30 respectively. So that if the water level is high than 8 it won't discharge the water and as the logic code for alarm is when the water level is 30 it won't even alarm ever as seen in figure 11 and figure 12.

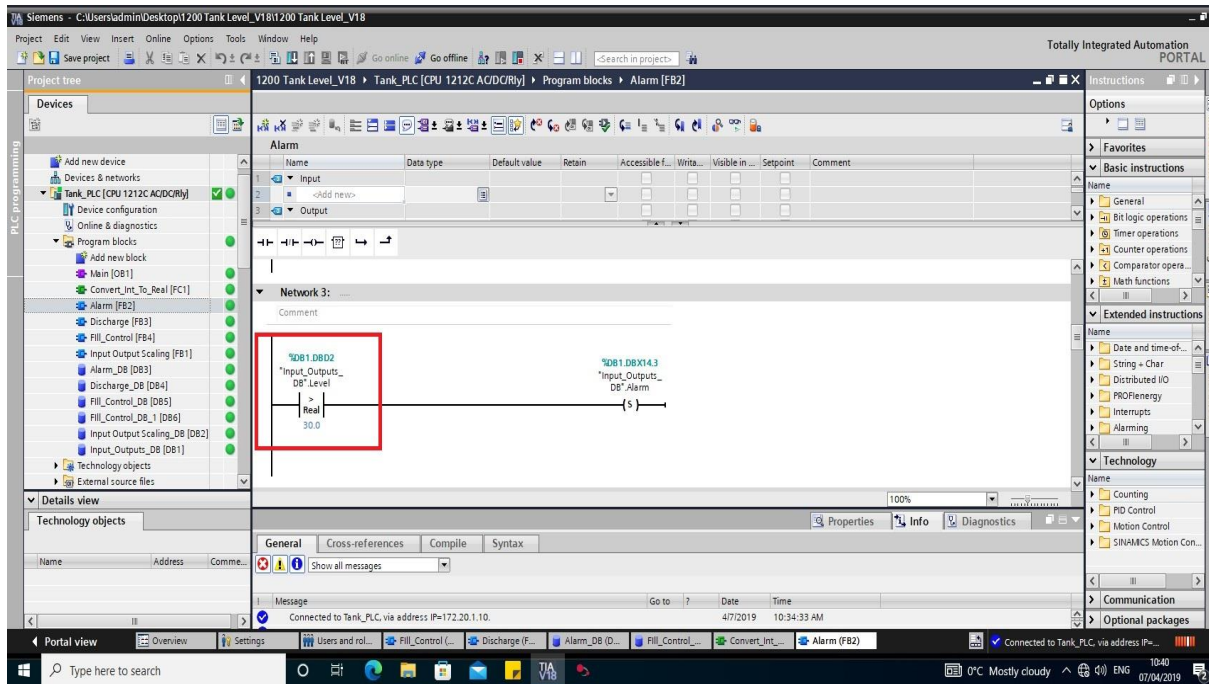


Figure 11

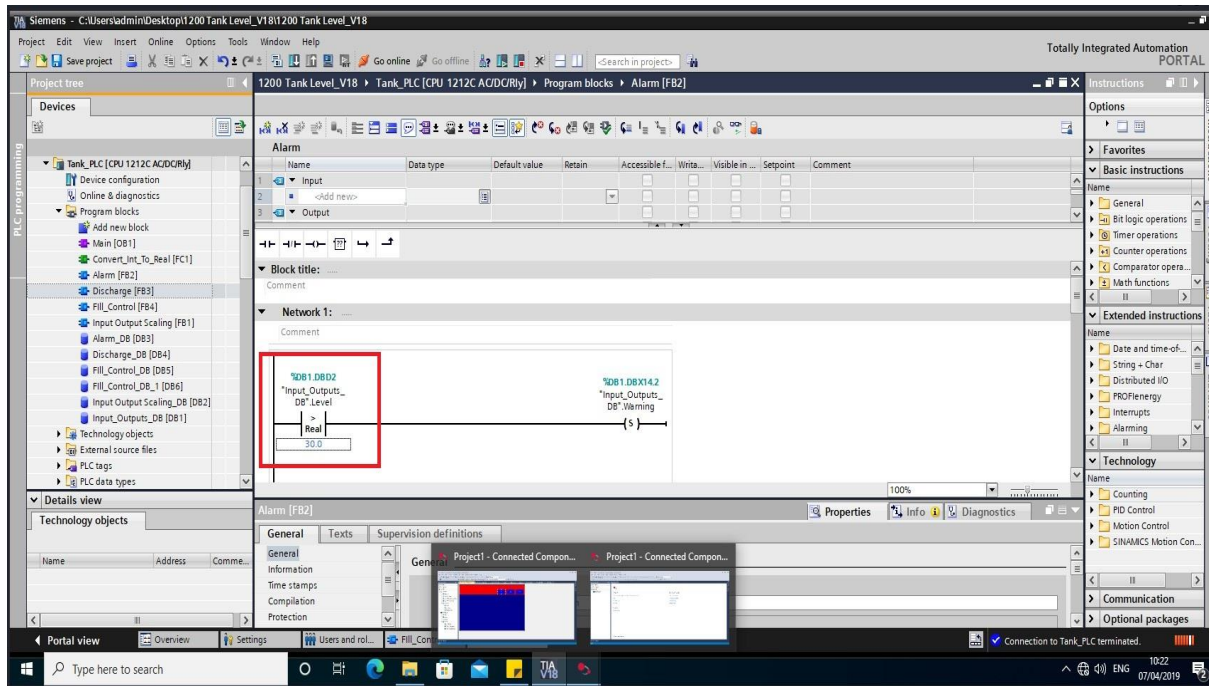


Figure 12

I then checked if my logic codes worked or not but checking the HMI itself and it worked as the water level got full and no alarm no discharge as well the filling was not stopped even when the level breached 8. This shows that how changing the logic/program code make the whole infrastructure go downhill.

But as HMI had the drain water / emergency drain water button. I switched off that as well by just going to root screen and getting into the events for that button and removed the login or tag behind it.

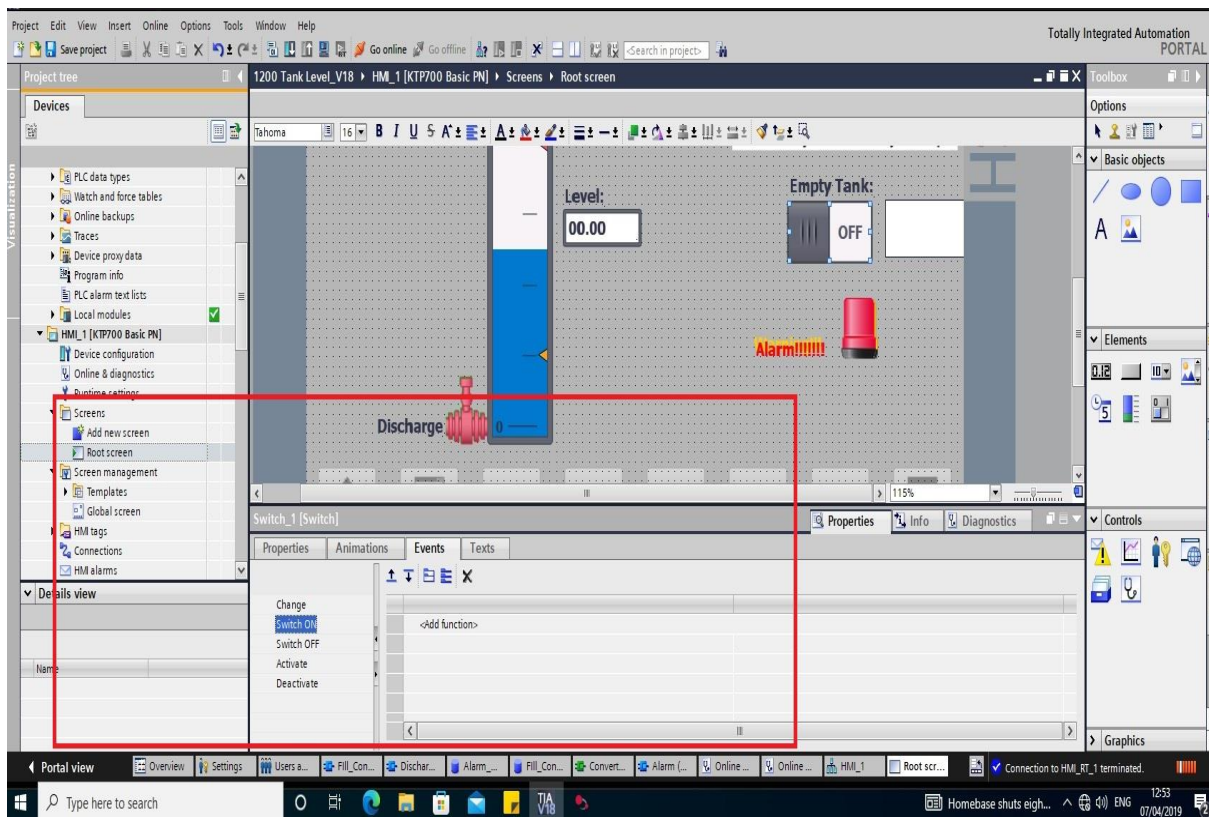


Figure 13

Even after the water level going above exceeded level the engineer cannot do anything as the empty tank button also will not work as seen in the Figure 14, 15 and 16.

This was the RDP vulnerability where the open port of RDP led to disastrous situation. The main part the CCTV camera where I can directly see into the camera without any login or permission. The last, the username and password was written on a page where we can clearly see and misuse.

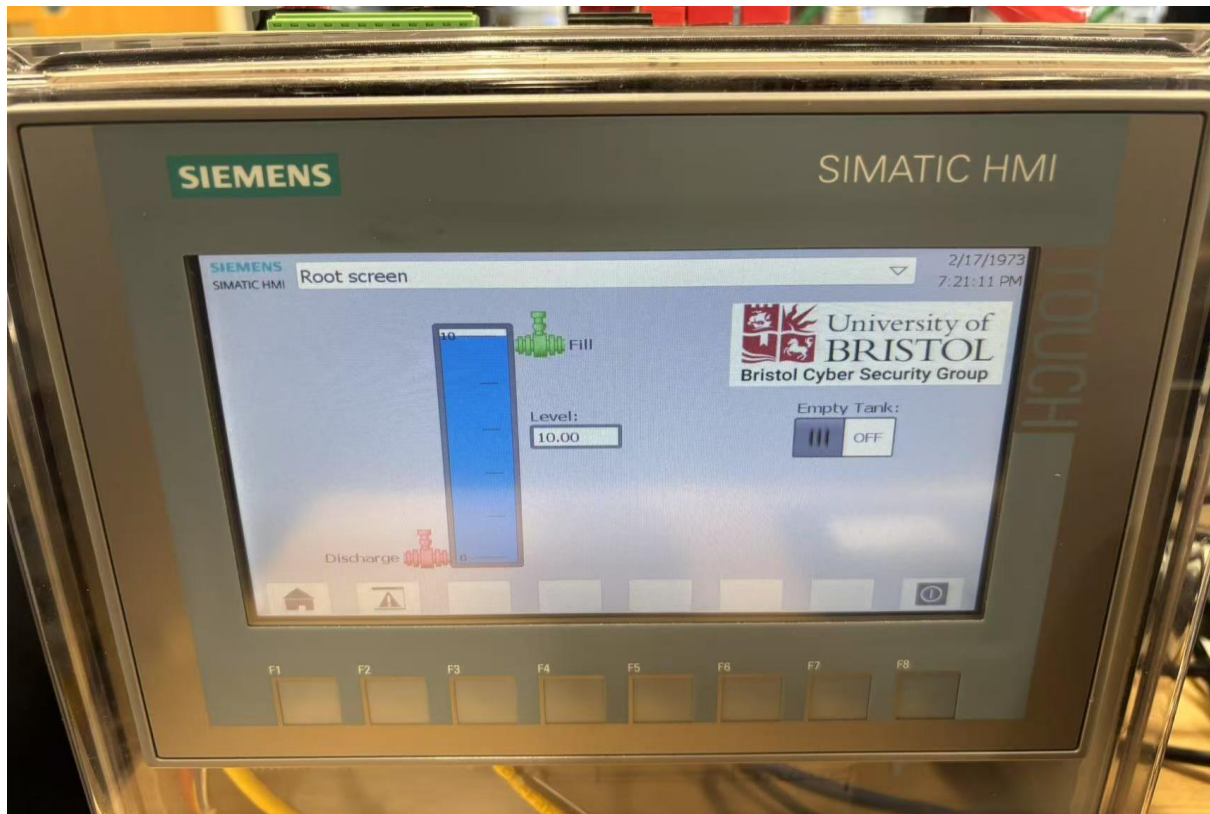


Figure 14

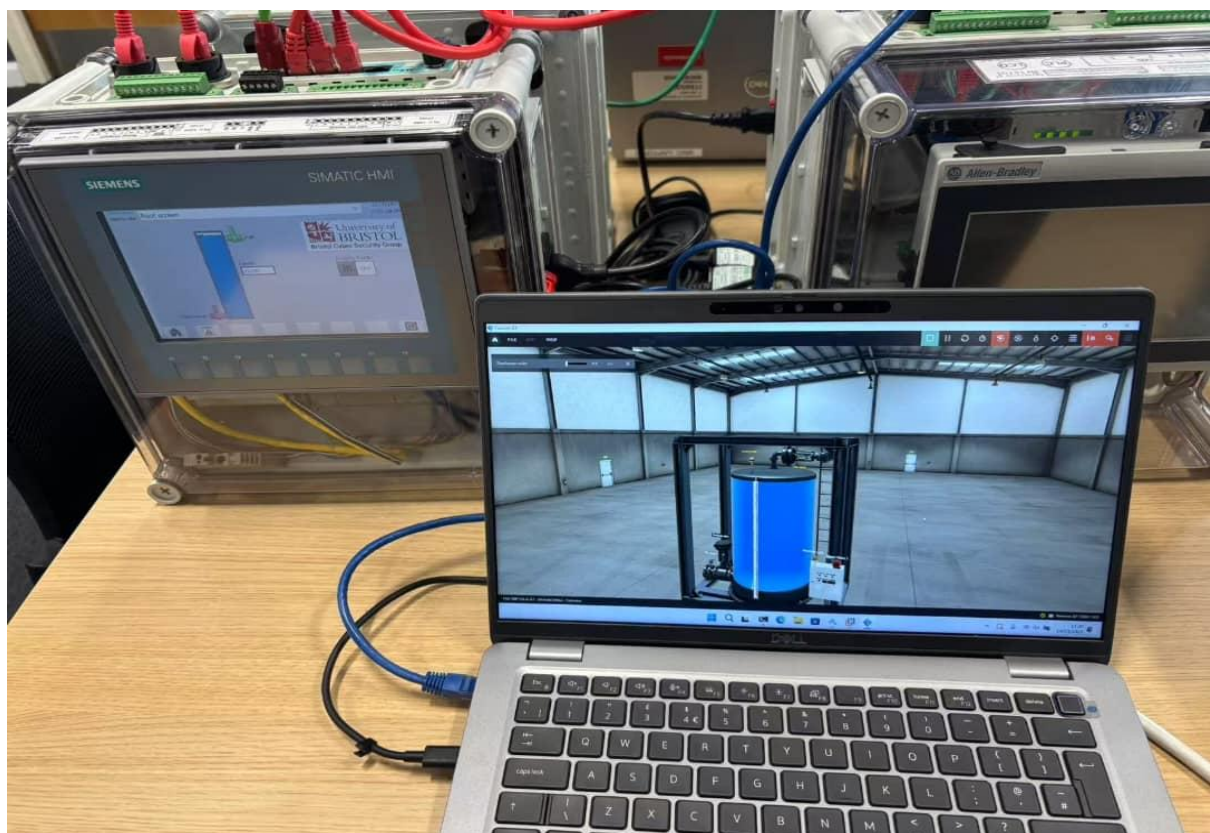


Figure 15



Figure 16

3. Mitigation Strategies

3.1 STRIDE Threat Analysis for Remote Desktop Protocol (RDP)

3.2 Unauthority access to Web monitoring

The monitoring interface lacks robust authentication controls, enabling unauthorized users to access the page by simply navigating to the exposed IP address (obtained

via network scanning tools such as Nmap). This absence of authentication mechanisms allows unrestricted access to sensitive operational data, posing risks of information leakage and potential exploitation by malicious actors.

Mitigations:

Implement Multi-Factor Authentication (MFA): Integrate a secure authentication protocol (e.g., OAuth 2.0, SAML, or Basic Auth over HTTPS) to enforce identity verification. Failed authentication attempts should trigger account lockout policies or rate-limiting to deter brute-force attacks.

Network Segmentation and IP Whitelisting: Restrict access to the monitoring interface by segmenting the network and enforcing IP whitelisting rules. Only pre-authorized administrative IP ranges or VLANs should be permitted access.

Role-Based Access Control (RBAC): Assign granular permissions to users based on the principle of least privilege (PoLP), ensuring only authorized personnel with explicit roles can view or interact with monitoring data

B) Credential Exposure in Monitoring Systems

Sensitive credentials (e.g., usernames and passwords) are stored or displayed in plaintext within the monitoring interface, creating opportunities for lateral movement or privilege escalation if intercepted by unauthorized users.

Mitigations:

Secure Credential Storage: Utilize encrypted credential vaults (e.g., HashiCorp Vault, AWS Secrets Manager) or hardware security modules (HSMs) to store credentials. Ensure encryption-in-transit (TLS 1.3+) and encryption-at-rest (AES-256) are enforced.

Eliminate Hardcoded Credentials: Remove credentials from frontend interfaces and

scripts. Instead, leverage ephemeral credentials or service accounts with short-lived tokens (e.g., OAuth2 tokens, AWS IAM Roles).

Audit Logging and Monitoring: Deploy security information and event management (SIEM) tools to log access attempts to credential storage systems and trigger alerts for anomalous activity.

C) Web Monitoring Vulnerabilities and Security Mitigations

The two passwords that were found are both weak (Password123 and Password1), which means that they can be easily under violent cracking. Command like Hydra can crack it in a short time.

6. Indicator of compromise (IOC)

A) Unauthorized access to Web monitoring

IOC: (1)Unauthorized HTTP requests

(2)Sensitive path access

Detection: (1)HTTP log analysis, such as searching for unauthorized path access and non-white IP addresses list.

(2)Snort rule monitoring like monitoring HMI unauthorized access.

B) Credentials exposure

IOC: (1)Abnormal authentication attempt

(2)The geographic location used for credentials is abnormal

Detection: (1)Monitor login events using Event Viewer on Windows and check auth.log on Linux.

(2)Record every login source IP and trigger geographic location change alarm.

C) Weak password vulnerability

IOC: (1)Large number of failed login attempts

(2)Abnormal account activity

Detection: (1)Search for login log analysis.

(2)Use User Behavior Analysis (UBA) or Security Information and Event Management (SIEM) systems to monitor behavior patterns after login and identify any unusual activity or access patterns.

D) Remote Desktop Vulnerability

IOC: (1)RDP port exposure and port scanning activity

(2)RDP login from uncommon IP addresses or geographical locations

Detection: (1)Monitor inbound traffic and use firewall or IDS systems to detect brute

force cracking or port scanning activities. Use VPN or restrict access through Network Access Control (NAC).

(2) Monitor for abnormal IP address logins by analyzing IP addresses, geographic locations, or device fingerprints.

References:

1. Lou, X., & Tellabi, A. (2020). Cybersecurity threats, vulnerability and analysis in safety critical industrial control system (ICS). *Recent Developments on Industrial Control Systems Resilience*, 75-97.
2. Aslan, Ö., Aktuğ, S. S., Ozkan-Okay, M., Yilmaz, A. A., & Akin, E. (2023). A comprehensive review of cyber security vulnerabilities, threats, attacks, and solutions. *Electronics*, 12(6), 1333.
3. Ramirez, R., Chang, C. K., & Liang, S. H. (2022, November). PLC cyber-security challenges in industrial networks. In *2022 18th IEEE/ASME International Conference on Mechatronic and Embedded Systems and Applications (MESA)* (pp. 1-6). IEEE.
4. Macaulay, T., & Singer, B. L. (2011). *Cybersecurity for industrial control systems: SCADA, DCS, PLC, HMI, and SIS*. CRC Press.
5. Strohmier, H., Londhe, A. R., Clark, C. A., Pawar, R., & Kram, B. (2024, June). Exploring ICS/SCADA Network Vulnerabilities. In *International Conference on Human-Computer Interaction* (pp. 215-233). Cham: Springer Nature Switzerland.
6. Pan, X., Wang, Z., & Sun, Y. (2020). Review of PLC security issues in industrial control system. *Journal of Cybersecurity*, 2(2), 69.
7. Ani, U. D., Daniel, N., Oladipo, F., & Adewumi, S. E. (2018). Securing industrial control system environments: the missing piece. *Journal of Cyber Security Technology*, 2(3-4), 131-163.
8. Altulaihan, E., Almaiah, M. A., & Aljughaiman, A. (2022). Cybersecurity threats, countermeasures and mitigation techniques on the IoT: Future research directions. *Electronics*, 11(20), 3330.
9. Anderson, R. S. (2009). *Cyber security and resilient systems* (No. INL/CON-09-16096). Idaho National Lab.(INL), Idaho Falls, ID (United States).

10. Pattanayak, A., & Kirkland, M. (2018, October). Current cyber security challenges in ICS. In 2018 IEEE International Conference on Industrial Internet (ICII) (pp. 202-207). IEEE.

11. Ramirez, R. P., Nguyen, T. D., Rowe, N. C., & Meier, J. T. (2022, December). Classifying RDP remote attacks on user interfaces to industrial control systems. In 2022 Internation